SEAT NO. CR-23009

NED UNIVERSITY OF ENGINEERING & TECHNOLOGY

THIRD YEAR(Cyber Security)

FALL SEMESTER EXAMINATIONS 2025

Time : 3 Hours | Batch 2023 | Dated : 15-DEC-25

Max Marks : 60

Information Assurance - CT-476

Note: *Attempt all questions. All questions carry equal marks.*

Scenario 1 (for Q1, Q2, Q3): **Data Breach and Insider Threat at Horizon Medical Research Center**

In early October, Horizon Medical Research Center discovered that several gigabytes of sensitive patient research data—including genomic records and clinical trial results—had been exfiltrated over a period of three weeks. The breach was traced back to an internal research assistant who misused privileged access. The assistant had connected an unauthorized personal laptop to the internal network, installed unapproved cloud storage applications, and gradually uploaded confidential datasets. The breach led to violations of research ethics guidelines, potential non-compliance with national privacy regulations, and serious reputational damage for the research center.

The Security Team initiated the Incident Response Process: Preparation, Detection & Analysis, Containment, Eradication & Recovery, and Post-Incident Activity.

(CLO1-C2)

Q1(a) Explain the significance of effective access control and monitoring in the preparation phase of the incident response process. Based on the scenario, what preparation measures should have been implemented to reduce the likelihood of insider misuse of sensitive research data?

Q1(b) Discuss how digital forensics tools (e.g., memory analysis, log correlation, network traffic inspection) can support the detection and analysis of insider data exfiltration activities in this scenario.

(CLO2-C5)

Q2 (a) Identify appropriate short-term and long-term containment strategies for stopping ongoing data exfiltration by an insider. Explain why containment must be prioritized before attempting eradication actions in this situation.

Q2 (b) Describe the steps required to securely restore affected systems and research data repositories. How should the recovery process be tested and validated to ensure no persistence mechanisms or unauthorized access paths remain?

(CLO3-C6)

Q3 (a) Propose key lessons learned and documentation activities that Horizon Medical Research Center should perform after resolving the insider-related data breach. Consider policy, technical, and training implications.

Q3 (b) Analyze the legal and ethical issues arising from this insider breach, including privacy violations and improper handling of patient research data. Recommend how the institution should address regulatory reporting, ethical compliance, and internal disciplinary actions.

Scenario 2 (for Q4): **Risk Assessment in a Smart Campus IoT Environment**

*A university has recently deployed a **Smart Campus IoT ecosystem**, including smart lighting, biometric attendance systems, IP surveillance cameras, environmental sensors, and Wi-Fi–enabled classroom devices. The IT Security Team notices increased security concerns after several anomalies:*

- *Multiple **IoT cameras began sending abnormal outbound traffic**, suggesting possible botnet activity.*
- *A vulnerability scan revealed **default credentials still active** on several biometric devices.*
- *A student reported receiving a **spoofed Wi-Fi login page**, indicating a potential phishing attempt targeting the new IoT-integrated network authentication system.*

*To assess these risks, the IT department performs **both quantitative and qualitative risk assessments**.*

- *In the **quantitative assessment**, they calculate the potential financial loss if biometric attendance data is compromised to be **Rs. 3 million**, with a probability score of 0.3.*
- *In the **qualitative assessment**, a risk matrix is used to categorise threats (IoT botnet attacks, credential compromise, phishing) into likelihood and impact levels: low, medium, or high, based on expert judgment and historical incident data.*

P.T.O

CamScanner

(CLO1-C2)

Q.4. Explain how both quantitative and qualitative risk assessment methods were applied in Scenario 3 above. Discuss the advantages and limitations of each approach when assessing risks in a Smart Campus IoT environment.

Scenario 3: Multi-Vector Cyber Threats Against a National Research Institute

The National Institute for Climate and Environmental Research (NICER) recently experienced a surge in coordinated cybersecurity incidents.

- *SOC analysts detected **brute-force login attempts** on high-performance computing (HPC) clusters containing climate-modelling datasets. The attempts originated from anonymized VPNs and Tor exit nodes.*
- *A senior researcher reported receiving a **spear-phishing email** pretending to be from a well-known government funding agency requesting login credentials to "verify grant documents."*
- *Physical security guards intercepted an **unknown individual tailgating** into a restricted server room, claiming to be a contractor but lacking authorization.*
- *The institute's legal office received a **ransom-like email** threatening to sabotage sensor networks deployed in remote monitoring stations unless a payment was made. The attackers demonstrated limited proof by temporarily disabling one sensor node.*

These incidents raised major concerns about state-sponsored espionage, organized cybercrime, insider threats, and hacktivist groups targeting environmental research.

(CLO2-C5)

Q.5 Evaluate the types of cybersecurity threat actors likely involved in Scenario 4 above. For each threat actor, assess their potential motivation, skill level, resource availability, and likely tactics. Explain how these assessments should guide NICER's incident response priorities and strategic decision-making.

Scenario 4: *CSIRT and Incident Investigation*

*Riverdale Technical University (RTU) experienced a sudden and severe **DDoS attack** that caused intermittent outages in the Learning Management System (LMS), email services, and remote-access portals.*

*Initial monitoring revealed that the attack traffic was partially originating from **RTU's own IoT devices**, including smart classroom sensors, IP surveillance cameras, and biometric attendance terminals—indicating possible compromise of internal systems.*

The Computer Security Incident Response Team (CSIRT) was immediately activated.

During the initial triage, CSIRT found:

- *IoT devices communicating with known botnet Command-and-Control (C2) servers.*
- *Default or weak credentials still active on several devices.*
- *Unauthorized firmware modifications on some cameras.*
- *Suspicious firewall rule changes that allowed outbound traffic to untrusted IP ranges.*

The incident degraded campus operations, disrupted teaching activities, and raised concerns about unauthorized access to stored recordings and attendance records.

CSIRT initiated a multi-layered investigation involving traffic analysis, IoT endpoint forensics, firmware integrity checks, reviewing network segmentation policies, and coordinating with vendors and legal advisors. They also started containment activities, such as isolating IoT networks, blocking outbound C2 traffic, and conducting emergency credential resets.

(CLO3-C6)

Q. 6 Design a comprehensive incident investigation and response strategy for Scenario 4 above. Your strategy should clearly outline:

1. CSIRT Roles and Responsibilities
2. Evidence Collection and Handling Procedures
3. Coordination Mechanisms
4. Internal and External Communication Protocols
5. Containment, Eradication, and Recovery Plans
6. Post-Incident Reporting and Lessons Learned

THE END

CamScanner

SEAT NO. CR-23009

NED UNIVERSITY OF ENGINEERING & TECHNOLOGY

THIRD YEAR(Cyber Security)

FALL SEMESTER EXAMINATIONS 2025

Time : 3 Hours | Batch 2023 | Dated : 10-DEC-25

Max Marks : 60

Cyber Security Laws and Regulations - CT-374

Note: Attempt all questions. All questions carry equal marks.

Q1: *Analyze* the role of psychological, sociopolitical, and ethical factors in cybersecurity with examples. Describe common ethical dilemmas in cybersecurity. **[CLO 3 – 10 marks]**

Q2: *Explain* why blockchain is a viable technology for protecting intellectual property (IP). Justify your answer with clear reasoning and examples. Explain potential drawbacks of using blockchain for IP protection and suggest at least two alternative technologies or methods for protecting IP. Explain why those alternatives may be effective, and compare them briefly with blockchain. **[CLO 2 – 10 marks]**

Q3: *Analyze* the purpose and scope of ISO/IEC 42001. Examine its limitations and gaps, considering technical, ethical, and organizational aspects. Propose specific, actionable improvements to enhance ISO/IEC 42001's applicability, robustness, and adoption in diverse organizational contexts. **[CLO 3 – 10 marks]**

Q4: *What* challenges financial institutions in Pakistan face when operating in the digital payments and cryptocurrency sectors, particularly concerning AMLA 2010 and SBP Regulations. What measures should these institutions take to ensure they meet legal requirements for anti money laundering (AML) and know your customer (KYC) obligations? **[CLO 1 – 10 marks]**

Q5: TechNova Services, a mid-sized company offering online subscription-based productivity and collaboration tools through both SaaS and mobile platforms, experienced rapid growth in its user base and transaction volume. With annual revenue of $35 million, 180 employees, and approximately 600,000 credit card transactions per year, the company accepted payments via major credit cards and digital wallets. As transaction activity increased, so did the risk of cardholder data exposure. This concern intensified after a surge in failed login attempts and a payment processing error that exposed partial customer card information. To safeguard sensitive data and maintain compliance, TechNova decided to fully adopt PCI DSS standards. During the initial assessment, several challenges emerged: the cloud infrastructure included outdated servers within the cardholder data environment (CDE) and weak TLS configurations for API communication; access management was poor, with developers and support staff sharing admin accounts and no MFA on critical systems; monitoring capabilities were limited, as logs were stored locally without centralization and no alerting system was in place for suspicious activity; and finally, third-party risks were significant because the company depended on multiple external services, including cloud storage, a mobile analytics SDK, and a payment gateway, none of which had been evaluated for PCI DSS compliance.

CamScanner

a) ***Discuss*** the key security weaknesses discovered during the gap analysis of TechNova Services.
b) For each weakness, ***explain*** which specific PCI DSS control should be implemented to address it.
c) ***Explain*** the PCI DSS merchant level that TechNova Services belongs to based on the information given in the case study. **[CLO 2 – 10 marks]**

Q6: For each security scenario described below, ***define*** specific CIS Controls that should be implemented.

a) The IT team needs a complete inventory of every physical and virtual device connected to the network to remove unauthorized systems.
b) The organization must ensure that only approved software is installed and running on enterprise assets, preventing unauthorized programs.
c) A process needs to be established for regularly identifying, triaging, and remediating weaknesses in systems and software.
d) A plan must be developed and tested to ensure that critical business data can be reliably restored after a major incident like a ransomware attack.
e) A security awareness program is being developed to train employees on identifying and avoiding social engineering and phishing attacks.
f) The IT security team wants to define and enforce standardized, secure baseline configurations for all new workstations and servers before deployment.
g) The organization needs to restrict administrative privileges and ensure that all high-level actions are performed using dedicated, secured accounts.
h) Processes must be established to manage the lifecycle of user, administrator, and service accounts, including timely disabling of dormant accounts.
i) The security team is implementing tools to collect, review, and retain detailed records of system events to aid in detecting and understanding suspicious activities.
j) The organization wants to deploy centrally managed anti-malware software across all enterprise assets to prevent the installation and execution of malicious code.

[CLO 1 – 10 marks]

CamScanner

SEAT NO. CR-23009

NED UNIVERSITY OF ENGINEERING & TECHNOLOGY

THIRD YEAR (COMPUTER SCIENCE SPECIALIZATION IN ARTIFICIAL INTELLIGENCE/ CYBER SECURITY)

FALL SEMESTER EXAMINATIONS 2025

BATCH 2023

Time: 3 Hours | **Dated: 05-DEC-25**

Max.Marks:60

Programming for Artificial Intelligence – CT-264

Intructions:

1.All Question carry equal marks
2. Draw diagrams where applicable
3. Write sample code to support your answers.

Q.1: (A) **DEFINE** the EDA and its types? Why EDA is import for machine learning applications? **(CLO-1, 6 Marks)**

(B) **DEFINE** tasks performed in each machine learning life cycle stage specifically performed in your developed project. **(CLO-1, 6 Marks)**

Q.2: Assume you are given the Titanic dataset (titanic.csv) and are using the pandas library in Python. **COVERT** each task given below into Python- code? **(CLO-2, 12 Marks)**

(a) Loading and Initial Inspection: Explain how you would load the dataset and perform an initial inspection to understand its structure, column data types, and the count of non-null values.

(b) Explain how you would inspection to understand its size and shape of data values.

(c) Cleaning - Missing Values (Imputation): Describe the code to handle missing values in the Age column by imputing with the median age.

(d) Cleaning - Irrelevant Features (Dropping): Explain the code you would use to drop the Cabin column from the dataset. Justify why this is a common step for this specific column.

(e) EDA - Univariate Analysis: Describe the code needed to visualize the distribution of passenger Age (e.g., using a histogram). What would this plot help you understand about the passengers?

(f) EDA - Bivariate Analysis: Describe the code (e.g., using .groupby()) to calculate the mean survival rate (Survived) for each Sex and Pclass (Passenger Class) combination. Explain what this analysis would reveal.

Q.3: (A) **DEFINE** Eigen Decomposition of a matrix, Singular Value Decomposition (SVD) and Principal Component Analysis (PCA) in detail. **(CLO-1, 6 Marks)**

(B) **EXPLAIN** the relationship between Eigen values and determinant of a matrix? What are the limitations of PCA? (12 Marks) **(CLO-2, 6 Marks)**

Q.4: (A) **WHAT** is dimensionality reduction in machine learning, and why is it important when working with high-dimensional datasets? What are the different algorithms for dimensionality reduction? **(CLO-1, 6 Marks)**

(B) **EXPLAIN** the difference between feature selection and feature extraction in dimensionality reduction. Define an Affine Transformation. **(CLO-2, 6 Marks)**

Q.5: (A) **DEFINE** the gradient descent algorithm its main goal? How does it work conceptually? What is the "gradient" and what role does it play in the process? **(CLO-1, 6 Marks)**

(B) **EXPLAIN the "learning rate" (alpha, α) why it is used?** EXPLAIN What happens if the learning rate is too large or too small? What is the update rule? Write the general formula for updating a parameter using gradient descent. **(CLO-2, 6 Marks)**

CamScanner

SEAT NO.-

NED UNIVERSITY OF ENGINEERING & TECHNOLOGY

THIRD YEAR(Cyber Security)

FALL SEMESTER EXAMINATIONS 2025

Time : 3 Hours | Batch 2023 | Date: --DEC-25 | Max Marks : 60

Information Security - CT-355

Question 1:

a) Explain the process of Security Risk Management within an organization. Discuss how risk identification and risk assessment contribute to strengthening organizational security. **[CLO-1, 6 Marks]**

b) Consider an organization facing frequent phishing attacks. Propose a risk treatment plan using appropriate tools or strategies. Justify why your selected approach is effective. **[CLO-2, 6 Marks]**

Question 2:

a) Describe the phases of a standard Security Incident Response Life Cycle. Why is effective incident response essential for business continuity? **[CLO-1, 6 Marks]**

b) A company detects unauthorized access to its customer database. Assess the techniques you would use to contain, eradicate, and recover from this incident. Provide reasons for each chosen technique. **[CLO-3, 6 Marks]**

Question 3:

a) Explain the relationship between Information Security goals (CIA triad) and cryptographic mechanisms. Provide an example for each security goal. **[CLO-1, 6 Marks]**

b) Compare Common Key (Symmetric) Cryptography and Public Key (Asymmetric) Cryptography in terms of performance, key management, and security. Provide scenarios where each method is most suitable. **[CLO-1, 6 Marks]**

Question 4:

a) What is a Public Key Certificate? Explain its structure and how a Certificate Authority (CA) ensures trust in digital communication. **[CLO-1, 6 Marks]**

b) Evaluate how Data Integrity and Digital Signatures work together to prevent message tampering. Provide a real-world example demonstrating the verification process. **[CLO-3, 6 Marks]**

Question 5:

a) Differentiate between Firewalls and Intrusion Detection Systems (IDS) in terms of functionality, placement, and threat detection capability. **[CLO-2, 6 Marks]**

b) A network administrator needs to secure a company network against external threats and insider misuse. Assess what combination of firewall types and IDS methods should be deployed. Justify your selection based on organizational needs. **[CLO-3, 6 Marks]**

CamScanner